

Static Security Analysis of AWS IAM Policies for AI Workload Identities

Detecting Excessive Privilege and Identity-Pivot Risks Before Deployment

CONTRIBUTION

A deterministic, non-executing IAM linter specialized for AI-agent roles with 25 rule IDs spanning identity policies, trust policies, and permission-boundary risks, emitting text, JSON, and SARIF for pre-deployment review and CI gating.

METHOD

- 01

Parse one IAM policy document without executing cloud actions.
- 02

Classify statements and trust-policy structure.
- 03

Apply deterministic rule checks for privilege escalation, excessive privilege, trust weaknesses, audit tampering, and missing boundaries.
- 04

Emit findings with stable rule IDs and severity.
- 05

Return CI-friendly exit codes and optional SARIF.

BOUNDARIES / LIMITATIONS

- Performance values are CI microbenchmarks on synthetic policies, not production SLOs.
- The tool is a static analyzer, not a runtime authorization proxy.
- It does not prove account-wide effective permissions or every cross-resource escalation path.
- The 3 skipped tests require live AWS credentials; users must supply their own credentials through the standard AWS provider chain.

CURRENT VERIFIED EVIDENCE

238	Tests collected
235	Tests passed
3	Tests skipped
25	Deterministic rule IDs
1.1460 ms	Synthetic-policy p95

EVIDENCE NOTES

1,846 policies/sec

Synthetic-policy throughput

- 238 collected: 235 passed, 3 skipped, 0 failures/errors.
- 25 deterministic rule IDs remain implemented and test-covered.
- Current performance gate over 500 synthetic policies: 1,1460 ms p95 and 1,846 policies/sec, both passing configured gates.

REPRODUCE

```
git clone https://github.com/poojakira/aws-agent-identity-guard.git
cd aws-agent-identity-guard
git checkout c39ba67f43ef6ebddd03a8ce429b42afec0c08a9
python -m pip install -e ".[dev]"
pytest tests/ -q
python benchmarks/perf_gate.py
```